

Smart Home Security Compliance Policy Documentation

Group #2: Ahmad Barakat, Hasanain AlSaid, Damion Tsosie

University of Kansas

ITEC 490: ITEC Capstone

Professor Chris Seasholtz

March 08, 2026

Table of Contents

Table of Contents.....	2
Introduction.....	3
Security Objectives.....	3
Security Architecture.....	4
Identity and Access Management (IAM).....	4
Data Protection & Encryption.....	5
IoT Device Security.....	5
Logging, Auditing, & Monitoring.....	6
Regulatory & Industry Compliance.....	6
Incident Response & Recovery.....	6
Risk Assessment & Future Growth.....	7
Citations.....	8

Introduction

The Smart Home Management Application integrates multiple internet of things devices including cameras, HVAC systems, lighting, and smart appliances into a unified dashboard. Because these devices operate within a residential setting and can handle sensitive data such as video streams and device usage patterns, cybersecurity protections are required to keep availability, integrity and confidentiality.

This document will outline the security controls, compliance considerations, and policies implemented within the system.

Security Objectives

Core Security Goals:

Confidentiality

- Device data, sensitive (video/audio) must be inaccessible to unauthorized entities.

Integrity

- Cryptographic hashing and digital signatures must be used to ensure that a command is sent to a device like opening a door, actions must originate from a verified user.

Availability

- Keep continuous access to critical systems such as cameras and security alerts for 24/7 protection in order to remain functional during network outages.

Security Architecture

The application will follow the **Defense-in-Depth** and **Zero Trust** models

Key Components

- **User Authentication Layer:** Identity verification using hashed credentials and multi-factor authentication (MFA).
- **Secure API Gateway:** All front-end requests must pass through a hardened gateway to prevent Denial of Service (DoS) attacks.
- **Encrypted Device Communication:** Ensures data packets move in secure protocols to prevent eavesdropping.
- **Access Control System:** Centralized engine that evaluates user permissions before executing device commands.

Identity and Access Management (IAM)

Multi-Factor Authentication (MFA): Required for all administrative actions and first time logins.

Role-Based Access Control (RBAC):

Role	Permissions
Owner	Full access to all devices
Family member	Limited control of devices
Guest	Temporary device access with limited control

Session Hardening: Application sessions must expire after 30 minutes of inactivity to prevent unauthorized physical access.

Data Protection & Encryption

Encryption at Rest: Stored sensitive data (credentials, logs) must be encrypted using AES-256

Encryption in Transit: All network traffic must be enforced with TLS 1.3.

Media Security: Live video feeds will utilize SRTP (Secure real-time Transport Protocol) to ensure full privacy of camera data.

Protected Data Includes

- Camera footage
- User credentials
- Device configuration
- Automation schedules

IoT Device Security

Zero-Trust Onboarding: Devices must be authenticated with a unique Device Secret.

Hardcoded passwords must be rotated during the initial setup.

Firmware Verification: The system will reject any package without a valid cryptographic signature.

Network Segmentation: Users are encouraged to use separate VLAN to prevent lateral movement to personal computers.

Logging, Auditing, & Monitoring

Immutable Audit Logs: The system will record every “state change” like opened doors, camera enabling, with a timestamp.

Real-Time Alerting: Users must receive push notifications for “High-Risk Events”, such as 3 consecutive failed login attempts, or new device registration.

Regulatory & Industry Compliance

The application aligns with the following frameworks:

- **NIST IR 8259:** Foundational Cybersecurity Activities for IoT
- **OWASP IoT Top 10:** Address common vulnerabilities like insufficient privacy protection, or insecure web interfaces.

Incident Response & Recovery

Automated Containment: If a device shows suspicious behavior like unauthorized data going out, the API Gateway will automatically revoke its tokens.

Disaster Recovery: Configuring backups must be maintained to allow for immediate system restoration after a hardware failure or a security breach

Risk Assessment & Future Growth

Vulnerability Management: The app will check connected device IDs against CVE (Common Vulnerabilities and Exposures) databases regularly to warn users of unpatched hardware.

AI Integration: Future versions will implement behavioral baselining to detect uncommon behavior in device usage

Citations

1. Findley, S. (2025, December 29). *Security & Compliance in home care software: Ensuring client confidentiality & data integrity*. AxisCare.
<https://axiscare.com/blog/security-and-compliance-in-home-care-software/>
2. Koch, E. M. (2025, March 10). *What are guidelines for Home Security?*. Oatridge Security Group, Inc. <https://oatridgesecurity.com/what-are-guidelines-for-home-security/>
3. *NISTIR 8259 series*. NIST. (2021, November 16).
<https://www.nist.gov/itl/applied-cybersecurity/nist-cybersecurity-iot-program/nistir-8259-series>